משרד החינוך · מגמת תקשוב · שאלון 735001 שנת הלימודים תשפ"ז

דף עבודה מס' 3

מבוא לאיומי רשת

עקרונות CIA, שפת הסיכון, תוקפים, נוזקות, התקפות מניעת שירות, הנדסה חברתית ובקרות

שם התלמיד/ה:		**כיתה:**	
תאריך:		**שם המורה:**	

מטרות הלמידה – בסיום דף העבודה התלמיד/ה יוכל/תוכל:

- להגדיר את שלושת עקרונות אבטחת המידע – סודיות, שלמות וזמינות – ולסווג אירועים לפיהם.
- להבחין בין המושגים נכס, פגיעות, איום, סיכון ובקרה.
- למיין סוגי תוקפים וסוגי נוזקות לפי מאפייניהם.
- להסביר כיצד פועלות התקפות DoS ו-DDoS והתקפות הנדסה חברתית.
- לסווג בקרות אבטחה לפי סוגן (מנהלית, פיזית, לוגית) ולפי תפקידן (מונעת, מגלה, מתקנת).

הנחיות לתלמיד/ה

קראו את חלק א' ואת הדוגמאות הפתורות. ענו על שאלות חלק ב' ורשמו את תשובותיכם בטבלת התשובות. בחלק ג' ענו בשפה מלאה ומנומקת. משך העבודה המומלץ: שני שיעורים (90 דקות).

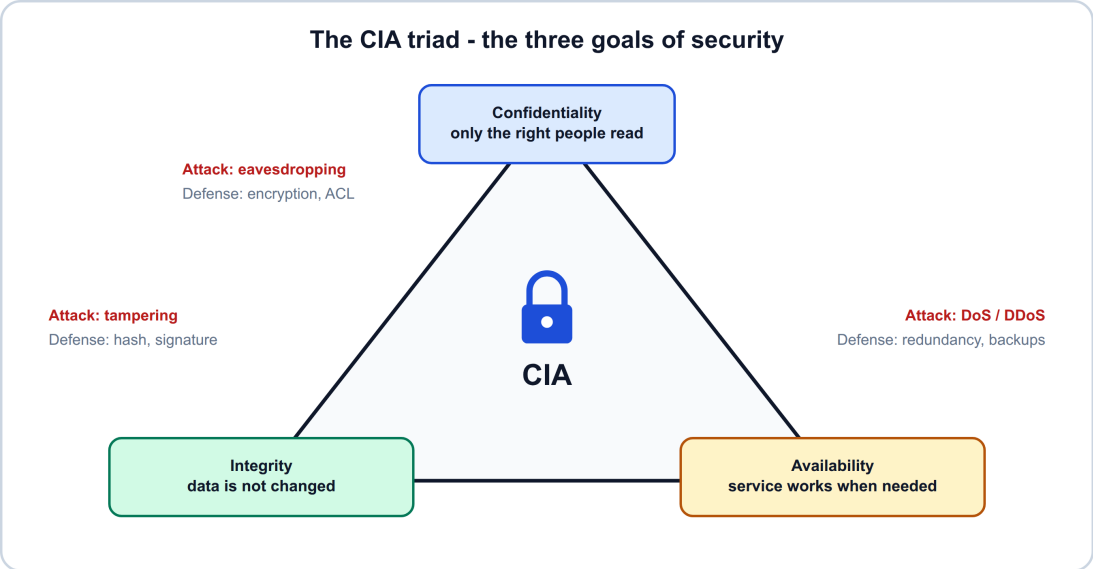
חלק א' – חומר עיוני

1. מהי אבטחת מידע?

הגדרה: אבטחת מידע (Information Security)

הגנה על מידע ועל המערכות המחזיקות אותו מפני גישה, שימוש, שינוי, חשיפה או השמדה בלתי מורשים. **אבטחת רשת** (Network Security) היא התחום העוסק בהגנה על המידע בזמן שהוא עובר ברשת, ועל רכיבי הרשת עצמם.

2. שלושת עקרונות היסוד – משולש CIA



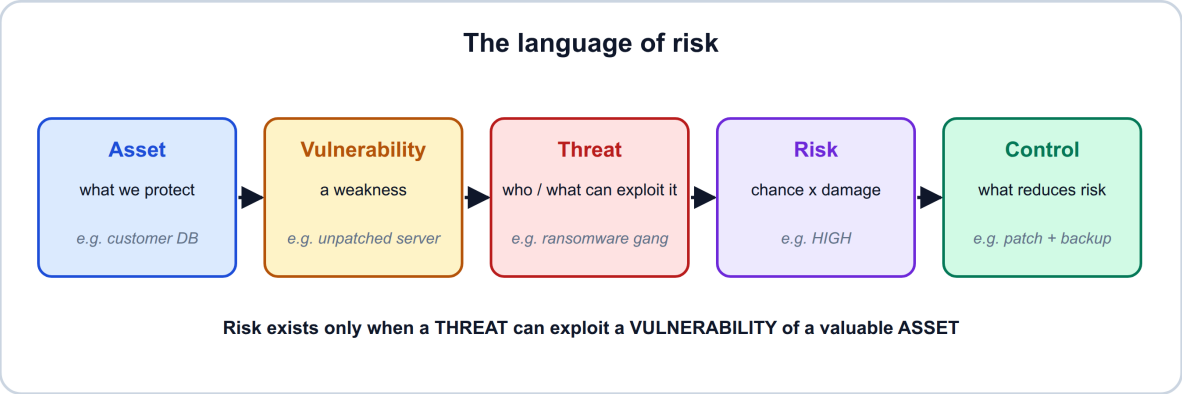
איור 1: משולש CIA: לכל עיקרון – התקפה טיפוסית הפוגעת בו ובקרה טיפוסית המגינה עליו.

עיקרון	משמעות	דוגמה לפגיעה	דוגמה להגנה
סודיות (Confidentiality)	רק מורשים יכולים לקרוא את המידע	האזנה לתעבורה, דליפת מאגר לקוחות	הצפנה, הרשאות גישה
שלמות (Integrity)	המידע לא שונה ללא הרשאה	שינוי ציון במערכת, זיוף העברה בנקאית	גיבוב (Hash), חתימה דיגיטלית
זמינות (Availability)	המידע והשירות נגישים כאשר צריך אותם	התקפת DDoS, כופרה, תקלת חשמל	גיבויים, יתירות, ספק כוח אל-פסק

דוגמה פתורה: סיווג אירועים לפי CIA

1. תלמיד מצא דרך לשנות את ציוניו במערכת בית הספר ← **שלמות**.
2. אתר ההרשמה של בית הספר קרס בגלל עומס מכוון ← **זמינות**.
3. רשימת טלפונים של הורים פורסמה ברשת החברתית ← **סודיות**.
4. כופרה הצפינה את שרת הקבצים, והתוקף מאיים לפרסם את הקבצים ← **זמינות וסודיות**.

3. שפת הסיכון



איור 2: שרשרת המושגים: נכס, פגיעות, איום, סיכון ובקרה.

מושג	הגדרה	דוגמה – חנות מקוונת
נכס (Asset)	כל דבר בעל ערך לארגון	מאגר הלקוחות
פגיעות (Vulnerability)	חולשה שניתן לנצל	שרת שלא עודכן חצי שנה
איום (Threat)	גורם שעלול לנצל את הפגיעות	קבוצת כופרה שסורקת את האינטרנט
סיכון (Risk)	הסבירות שהאיום יתממש כפול הנזק שייגרם	גבוה: סבירות גבוהה ונזק גבוה
בקרה (Control)	אמצעי שמקטין את הסיכון	עדכוני תוכנה, גיבוי לא מקוון

שימו לב

סיכון = סבירות × השפעה. אין סיכון כאשר אין נכס בעל ערך, כאשר אין פגיעות, או כאשר אין איום שמסוגל לנצל אותה.

4. מי הם התוקפים?

סוג	מאפיינים
כובע לבן (White Hat)	מומחה אבטחה הפועל **באישור** הבעלים כדי לאתר חולשות ולתקן אותן (בודק חדירות)
כובע שחור (Black Hat)	פורץ ללא אישור, למטרות רווח, נזק או גניבה
כובע אפור (Grey Hat)	פורץ ללא אישור אך ללא כוונת נזק, ולעיתים מדווח על החולשה
Script Kiddie	חסר ידע מעמיק, משתמש בכלים מוכנים של אחרים
האקטיביסט (Hacktivist)	פועל ממניעים פוליטיים או חברתיים
תוקף מדינתי	ממומן על ידי מדינה, בעל משאבים רבים, לריגול או לחבלה
גורם פנימי (Insider)	עובד או ספק בעל גישה לגיטימית שמנצל אותה לרעה

5. נוזקות (Malware)

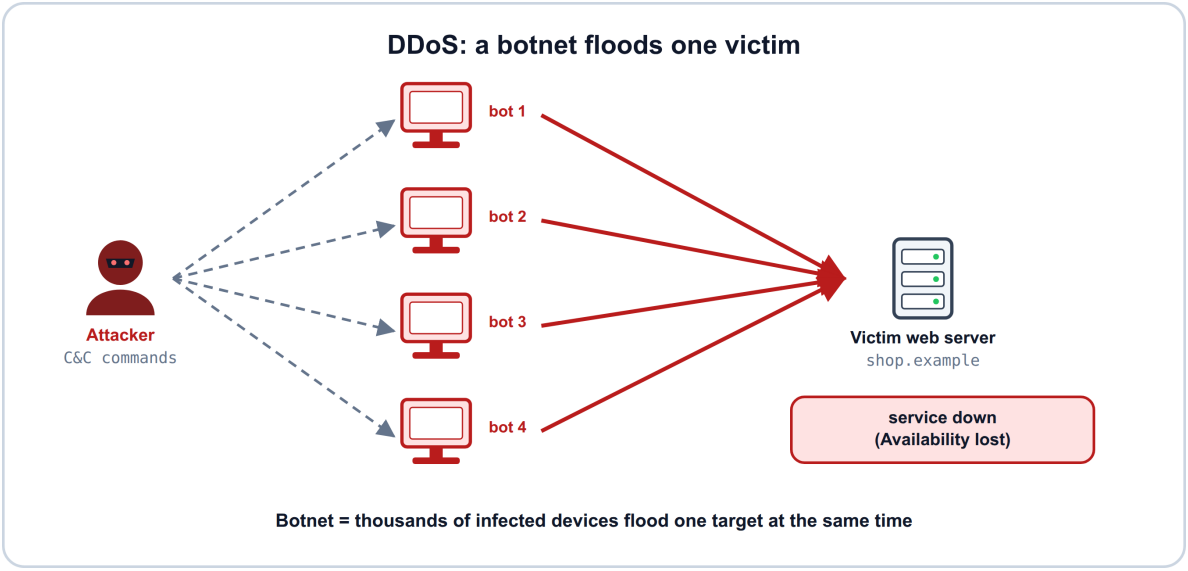
סוג	כיצד פועל
וירוס (Virus)	נצמד לקובץ או לתוכנה ומתפשט רק כאשר המשתמש מפעיל את הקובץ הנגוע
תולעת (Worm)	מתפשטת **באופן עצמאי** ברשת, ללא מעורבות המשתמש, על ידי ניצול פגיעות
סוס טרויאני (Trojan)	מתחזה לתוכנה לגיטימית שהמשתמש מתקין מרצונו, ומבצע פעולה זדונית ברקע
כופרה (Ransomware)	מצפינה את קבצי הקורבן ודורשת כופר תמורת מפתח הפענוח
רוגלה (Spyware)	אוספת מידע על המשתמש בסתר: הקשות, סיסמאות, אתרים
Rootkit	מסתירה את נוכחות התוקף במערכת ומעניקה לו הרשאות מנהל
Botnet	רשת של מכשירים נגועים ("זומבים") הנשלטים מרחוק על ידי התוקף

טעות נפוצה

"כל נוזקה היא וירוס". המילה "וירוס" משמשת בשפה היומיומית לכל נוזקה, אך במונחים מקצועיים וירוס הוא סוג אחד בלבד. ההבדל המרכזי בינו לבין תולעת: וירוס צריך שמישהו יפעיל אותו; תולעת מתפשטת לבד.

6. התקפות מניעת שירות – DoS ו-DDoS

התקפת מניעת שירות (DoS – Denial of Service) נועדה להשבית שירות כך שמשתמשים לגיטימיים לא יוכלו להשתמש בו. **בהתקפה מבוזרת** (DDoS – Distributed DoS) התוקף מפעיל בבת אחת אלפי מכשירים נגועים (Bot-net), ולכן קשה מאוד לחסום אותה לפי כתובת מקור אחת.



איור 3: התקפת DDoS: התוקף מפקד על רשת בוטים, וכולם מציפים שרת אחד בו-זמנית. העיקרון שנפגע – זמינות.

דוגמה פתורה: Mirai – 2016

הנוזקה Mirai סרקה את האינטרנט אחר מצלמות אבטחה ונתבים ביתיים שבהם נשארו סיסמאות ברירת המחדל של היצרן (כגון admin/admin), והשתלטה על מאות אלפי מכשירים. רשת הבוטים שנוצרה ביצעה

התקפת DDoS שהשביתה אתרים מרכזיים בארצות הברית. **הלקח:** פגיעות פשוטה – סיסמת ברירת מחדל – במכשירים רבים יצרה איום עצום. בקרה פשוטה – החלפת הסיסמה – הייתה מונעת זאת.

7. הנדסה חברתית – ההתקפה על האדם

הגדרה: הנדסה חברתית (Social Engineering)

תמרון פסיכולוגי של בני אדם כדי שימסרו מידע או יבצעו פעולה המסייעת לתוקף. ההתקפה מנצלת אמון, פחד, דחיפות או סקרנות – ולא חולשה טכנית.

- **דיוג** (Phishing) – הודעת דואר מתחזה עם קישור לאתר מזויף.
- **דיוג ממוקד** (Spear Phishing) – הודעה מותאמת אישית לאדם מסוים, על סמך מידע שנאסף עליו.
- **דיוג טלפוני** (Vishing) – שיחת טלפון מתחזה, למשל "מהבנק" או "מהתמיכה הטכנית".
- **התחזות** (Pretexting) – בניית סיפור כיסוי אמין כדי לקבל מידע.
- **השתחלות** (Tailgating) – כניסה פיזית לאזור מוגן בעקבות עובד מורשה.
- **פיתיון** (Baiting) – החדרת התקן USB נגוע שהושאר "בטעות" במקום ציבורי.

דוגמה פתורה: זיהוי הודעת דיוג

התקבלה הודעה: *"חשבונך ננעל! היכנס תוך 24 שעות לקישור http://paypa1-secure.com אחרת החשבון יימחק."*

1. **דחיפות ואיום** – *"תוך 24 שעות"*, *"יימחק"*: לחץ שנועד למנוע מחשבה.
2. **כתובת מזויפת** – הספרה 1 במקום האות l, ותחום שאינו של החברה.
3. **פרוטוקול לא מאובטח** – http ולא https.

הדרך הנכונה: לא ללחוץ על הקישור, להיכנס לאתר באופן עצמאי, ולדווח לצוות אבטחת המידע.

8. בקרות אבטחה

סוג בקרה	הסבר	דוגמאות
מנהלית	נהלים, מדיניות והדרכה	מדיניות סיסמאות, הדרכת עובדים, נוהל עדכונים
פיזית	הגנה על הגישה הפיזית לציוד	מנעול לחדר השרתים, מצלמות, כרטיס כניסה
לוגית (טכנית)	אמצעים בתוכנה ובחומרה	חומת אש, הצפנה, אנטי-וירוס, הרשאות

בנוסף, מסווגים בקרות לפי **תפקידן**: בקרה **מונעת** (חומת אש), בקרה **מגלה** (מערכת IDS, מצלמה), ובקרה **מתקנת** (שחזור מגיבוי).

אתיקה וחוק

בקורס לומדים כיצד פועלות התקפות – אך ורק כדי להתגונן מפניהן. חדירה למחשב או לרשת ללא הרשאה, ואף סריקה שלהם, אסורות על פי **חוק המחשבים, התשנ"ה–1995**. כל תרגול מעשי מתבצע רק בסביבת מעבדה שהוקצתה לכך, ובאישור המורה.

סיכום – מה חייבים לזכור

1. CIA: סודיות – מי קורא; שלמות – האם שונה; זמינות – האם זמין.
2. סיכון = איום שמנצל פגיעות של נכס; מצמצמים אותו בעזרת בקרות.
3. וירוס צריך הפעלה; תולעת מתפשטת לבד; טרויאני מותקן מרצון.
4. DDoS = הצפה מתואמת מרשת בוטים ← פגיעה בזמינות.
5. הנדסה חברתית תוקפת את האדם; ההגנה העיקרית – מודעות והדרכה, ואימות רב-שלבי.
6. בקרות: מנהלית, פיזית, לוגית; מונעת, מגלה, מתקנת.

חלק ב' – שאלות רב-ברירה

בכל שאלה בחרו את התשובה הנכונה וסמנו אותה. רשמו את אות התשובה בטבלת התשובות שבסוף החלק.

1. תלמיד שינה את הציון שלו במערכת בית הספר. איזה עיקרון נפגע?

☐ **א.** סודיות

☐ **ב.** שלמות

☐ **ג.** זמינות

☐ **ד.** אימות

2. התקפת DDoS פוגעת בעיקר ב:

☐ **א.** סודיות

☐ **ב.** שלמות

☐ **ג.** זמינות

☐ **ד.** אי-התכחשות

3. מה ההבדל העיקרי בין תולעת לווירוס?

☐ **א.** תולעת תמיד מוחקת קבצים

☐ **ב.** וירוס פועל רק בטלפונים

☐ **ג.** אין ביניהם הבדל

☐ **ד.** תולעת מתפשטת לבד ברשת; וירוס זקוק להפעלה על ידי משתמש

4. "משחק חינם" שהותקן מרצון ומפעיל ברקע תוכנת ריגול הוא:

☐ **א.** וירוס

☐ **ב.** תולעת

☐ **ג.** סוס טרויאני

☐ **ד.** Rootkit

5. שרת שלא עודכן שנה הוא דוגמה ל:

☐ **א.** פגיעות

☐ **ב.** איום

☐ **ג.** נכס

☐ **ד.** בקרה

6. הדרכת עובדים לזיהוי הודעות דיוג היא בקרה:

☐ **א.** פיזית

☐ **ב.** לוגית

☐ **ג.** מנהלית

☐ **ד.** מתקנת

7. אדם התקשר לעובד, הציג את עצמו כאיש התמיכה וביקש את סיסמתו. זו התקפת:

☐ **א.** Vishing

☐ **ב.** DDoS

☐ **ג.** תולעת

☐ **ד.** Tailgating

8. איזו בקרה מגינה בעיקר על **סודיות** מידע העובר ברשת?

☐ **א.** הצפנה

☐ **ב.** גיבוי יומי

☐ **ג.** ספק כוח אל-פסק

☐ **ד.** יתירות שרתים

9. מהו "כובע לבן"?

☐ **א.** פורץ למטרות רווח

☐ **ב.** מפיץ נוזקות

☐ **ג.** מומחה הבודק מערכות באישור הבעלים כדי לשפר את אבטחתן

☐ **ד.** תוקף ממניעים פוליטיים

10. כופרה הצפינה את קבצי הארגון. איזו בקרה מאפשרת לחזור לעבודה בלי לשלם?

☐ **א.** חומת אש

☐ **ב.** גיבוי לא מקוון ומעודכן

☐ **ג.** סיסמה ארוכה

☐ **ד.** סינון דואר זבל

11. מצלמת אבטחה בחדר השרתים היא בקרה:

- ☐ **א.** פיזית ומגלה
- ☐ **ב.** לוגית ומונעת
- ☐ **ג.** מנהלית ומתקנת
- ☐ **ד.** לוגית ומגלה

12. מה הפך את רשת הבוטים Mirai לגדולה כל כך?

- ☐ **א.** פגיעות מתוחכמת במערכת ההפעלה
- ☐ **ב.** הנדסה חברתית של מנהלי רשת
- ☐ **ג.** הצפנה חלשה ב-Wi-Fi
- ☐ **ד.** מכשירים רבים עם סיסמאות ברירת מחדל של היצרן

טבלת תשובות – רשמו בכל משבצת את אות התשובה הנכונה

שאלה	1	2	3	4	5	6	7	8	9	10	11	12
תשובה												

חלק ג' – שאלות פתוחות ותרגילים

שאלה 1 (15 נק')

לכל אירוע ציינו איזה עיקרון (או עקרונות) של CIA נפגע, ונמקו במשפט אחד:

1. עובד שלח בטעות קובץ משכורות לכל עובדי החברה.
2. פורץ שינה את מספר החשבון בהוראת תשלום לספק.
3. הצפה של בקשות גרמה לאתר הקניות לקרוס ביום מבצעים.

שאלה 2 (15 נק')

בית ספר שומר את ציוני התלמידים בשרת בחדר המחשבים. הסיסמה למערכת היא 12345, והדלת לחדר אינה נעולה. זהו בתרחיש: נכס, שתי פגיעות, איום אחד, ושתי בקרות מתאימות (ציינו את סוג כל בקרה).

שאלה 3 (10 נק')

הסבירו את ההבדל בין התקפת DoS להתקפת DDoS, וציינו מדוע קשה יותר להתגונן מפני DDoS.

שאלה 4 (10 נק')

התקבלה ההודעה הבאה: "שלום, כאן מחלקת המחשוב. אנו מבצעים שדרוג דחוף ונדרשת סיסמתך עד סוף היום, אחרת חשבונך ייחסם." ציינו שלושה סימנים לכך שמדובר בהתקפת הנדסה חברתית, ומה עליכם לעשות.

שאלה 5 (10 נק')

שאלת חשיבה: מדוע הנדסה חברתית נחשבת לאחת ההתקפות היעילות ביותר, גם בארגונים עם חומות אש והצפנה מתקדמות? הציעו שתי בקרות נגדה.

בהצלחה!